SenseDrift

RAPPORT D'AUDIT AWS

Sécurité & optimisation des coûts

Préparé pour Exemple SAS

6 novembre 2026

COMPTE AWS	123456789012 (exemple-prod)
RÉGIONS ANALYSÉES	eu-west-3, eu-west-1
PÉRIODE D'ANALYSE	14 derniers jours (métriques) · 3 mois (facturation)
RÉFÉRENCE DU RAPPORT	SD-9012-20261106-0739
PRÉPARÉ PAR	SenseDrift

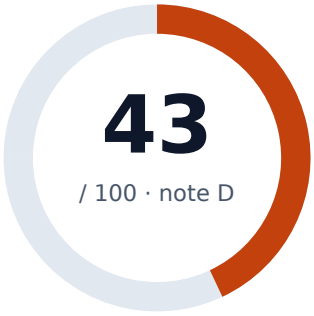
contact@sensedrift.fr · sensedrift.fr

Document confidentiel. Il décrit des faiblesses de configuration et ne doit être communiqué qu'aux personnes habilitées. Audit réalisé en lecture seule : aucune ressource n'a été modifiée.

SYNTHÈSE

Synthèse exécutive

L'analyse du compte **123456789012** a porté sur 2 région(s) et 15 services AWS. Le score de posture sécurité est de **43/100 (note D)** : 9 contrôle(s) de sécurité, de résilience ou de traçabilité sont en échec, dont **4 constat(s) critique(s)** et **8 élevé(s)**. Les gisements d'économies identifiés représentent environ **1 121 € par mois**, soit **13 453 € par an** (26 % de la dépense du dernier mois).



1 121 €
Économies estimées / mois

13 453 €
Économies estimées / an

4 287 €
Dépense du dernier mois

12
Constats critiques et élevés

Répartition des constats

4
Critique · sous 48 h

8
Élevée · sous 2 semaines

8
Moyenne · sous 1 mois

4
Faible · sous 3 mois

Les 5 actions prioritaires

#	Action	Niveau	Gain / mois
1	**Security Groups ouverts sur Internet** EC2 · 2 ressource(s) · Restreindre la source à des plages IP connues.	CRITIQUE	—
2	**Aucun trail CloudTrail multi-région actif** CloudTrail · 1 ressource(s) · Créer un trail multi-région vers un bucket S3 dédié, avec validation d'intégrité.	CRITIQUE	—
3	**MFA non activé sur le compte root** IAM · 1 ressource(s) · Activer immédiatement un MFA (clé FIDO2 de préférence) sur le root, et réserver ce compte aux rares opérations qui l'exigent.	CRITIQUE	—
4	**Instances surdimensionnées (Compute Optimizer)** EC2 · 2 ressource(s) · Redimensionner l'instance vers le type recommandé.	MOYENNE	**389 €**
5	**Engagement Compute Savings Plan recommandé** Savings Plans · 1 ressource(s) · Appliquer d'abord le redimensionnement, puis souscrire un Savings Plan.	MOYENNE	**318 €**

OPTIMISATION DES COÛTS

Où part votre budget AWS

Les montants de dépense proviennent de la facturation AWS (Cost Explorer). Les économies sont des estimations calculées à partir des tarifs publics et de l'usage observé.

Dépense mensuelle



Service (dernier mois)	Montant	Part
Elastic Compute Cloud - Compute	1 764 €	42 %
Relational Database Service	1 039 €	25 %
EC2 - Other	513 €	12 %
Simple Storage Service	288 €	7 %
CloudWatch	215 €	5 %
Virtual Private Cloud	168 €	4 %
Autres services	220 €	5 %

Gisements d'économies identifiés

Constat	Ress.	Confiance	€ / mois	€ / an
Instances surdimensionnées (Compute Optimizer) EC2	2	Élevée	389 €	4 672 €
Engagement Compute Savings Plan recommandé Savings Plans	1	Moyenne	318 €	3 816 €
Moteurs de base en fin de support (RDS Extended Support facturé) RDS	1	Élevée	251 €	3 013 €
Volumes EBS non attachés EBS	3	Élevée	80,41 €	965 €
Groupes de logs conservés indéfiniment CloudWatch Logs	1	Moyenne	33,24 €	399 €
NAT Gateways sans trafic NAT Gateway	1	Élevée	30,13 €	362 €
Volumes gp2 à migrer vers gp3 EBS	1	Élevée	18,92 €	227 €
Total estimé			**1 121 €**	**13 453 €**

Confiance — Élevée : ressource facturée sans usage. Moyenne : dépend de la mise en œuvre. Indicative : ordre de grandeur. Les engagements (Savings Plans, réservations) se cumulent partiellement avec le redimensionnement : les souscrire en dernier.

PLAN D'ACTION

Plan de remédiation priorisé

Chaque ligne regroupe toutes les ressources concernées par un même contrôle. Les échéances sont indicatives et proportionnées au niveau de risque.

Niveau	Action	Ress.	Effort	Échéance	€ / mois
CRITIQUE	**Security Groups ouverts sur Internet** EC2 · Sécurité	2	Faible	Sous 48 h	—
CRITIQUE	**Aucun trail CloudTrail multi-région actif** CloudTrail · Traçabilité & conformité	1	Faible	Sous 48 h	—
CRITIQUE	**MFA non activé sur le compte root** IAM · Sécurité	1	Faible	Sous 48 h	—
ÉLEVÉE	**Moteurs de base en fin de support (RDS Extended Support facturé)** RDS · Coûts	1	Élevé	Sous 2 semaines	251 €
ÉLEVÉE	**IMDSv2 non imposé sur les instances** EC2 · Sécurité	5	Faible	Sous 2 semaines	—
ÉLEVÉE	**Bases sans sauvegarde automatique** RDS · Résilience	1	Faible	Sous 2 semaines	—
ÉLEVÉE	**Utilisateurs console sans MFA** IAM · Sécurité	1	Faible	Sous 2 semaines	—
MOYENNE	**Instances surdimensionnées (Compute Optimizer)** EC2 · Coûts	2	Moyen	Sous 1 mois	389 €
MOYENNE	**Engagement Compute Savings Plan recommandé** Savings Plans · Coûts	1	Faible	Sous 1 mois	318 €
MOYENNE	**Volumes EBS non attachés** EBS · Coûts	3	Faible	Sous 1 mois	80,41 €
MOYENNE	**NAT Gateways sans trafic** NAT Gateway · Coûts	1	Faible	Sous 1 mois	30,13 €
MOYENNE	**VPC Flow Logs désactivés** VPC · Traçabilité & conformité	1	Faible	Sous 1 mois	—
FAIBLE	**Groupes de logs conservés indéfiniment** CloudWatch Logs · Coûts	1	Faible	Sous 3 mois	33,24 €
FAIBLE	**Volumes gp2 à migrer vers gp3** EBS · Coûts	1	Faible	Sous 3 mois	18,92 €
FAIBLE	**Instances sans aucun tag** EC2 · Gouvernance	1	Moyen	Sous 3 mois	—
FAIBLE	**Versioning désactivé** S3 · Résilience	1	Faible	Sous 3 mois	—

CONSTATS DÉTAILLÉS

Détail des constats et remédiations

Pour chaque contrôle en échec : le risque, la correction recommandée et la liste des ressources concernées.

CRITIQUE 1. Security Groups ouverts sur Internet

EC2 · CIS 5.2, CIS 5.3

Risque. Ces règles autorisent des connexions entrantes depuis n'importe quelle adresse IP. Les ports d'administration et de bases de données exposés sont scannés en permanence par des robots.

Correction. Restreindre la source à des plages IP connues. Pour l'administration, utiliser AWS Systems Manager Session Manager (aucun port à ouvrir).

Ressource	Détail	Région
`sg-0a41c9e2`	admin-bastion · TCP 22 — dont 22 (SSH)	eu-west-3
`sg-07be11f0`	legacy-db · TCP 5432 — dont 5432 (PostgreSQL)	eu-west-3

CRITIQUE 2. Aucun trail CloudTrail multi-région actif

CloudTrail · CIS 3.1

Risque. Les actions réalisées sur le compte ne sont pas archivées durablement. En cas d'incident, l'enquête sera très limitée.

Correction. Créer un trail multi-région vers un bucket S3 dédié, avec validation d'intégrité.

Commande

```
aws cloudtrail create-trail --name org-trail --s3-bucket-name <bucket-logs> --is-multi-region-trail
--enable-log-file-validation
```

CRITIQUE 3. MFA non activé sur le compte root

IAM · CIS 1.5

Risque. Le compte root a tous les droits, y compris fermer le compte ou modifier la facturation. Protégé par un simple mot de passe, il est la cible n°1.

Correction. Activer immédiatement un MFA (clé FIDO2 de préférence) sur le root, et réserver ce compte aux rares opérations qui l'exigent.

Ressource	Détail	Région
`root`		global

ÉLEVÉE

4. Moteurs de base en fin de support (RDS Extended Support facturé)

RDS

Risque. Le support standard de postgres 12 a pris fin le 28/02/2025. AWS facture désormais un supplément Extended Support par vCPU et par heure.

Correction. Planifier la montée de version majeure (Blue/Green Deployments RDS).

Économie estimée : 251 € / mois (3 013 € / an) · confiance élevée

Ressource	Détail	Région	€ / mois
prod-postgres	postgres 12.19 · db.m6g.xlarge	eu-west-3	251 €

ÉLEVÉE

5. IMDSv2 non imposé sur les instances

EC2 · CIS 5.6

Risque. Ces instances acceptent encore IMDSv1. Une vulnérabilité SSRF suffit à voler les identifiants IAM de l'instance.

Correction. Imposer IMDSv2 (aucun redémarrage nécessaire).

Exemple de commande

```
aws ec2 modify-instance-metadata-options --instance-id i-0abc… --http-tokens required
```

Ressource	Détail	Région
i-004f2a9c1e7b3d50	api-1	eu-west-3
i-014f2a9c1e7b3d51	api-2	eu-west-3
i-024f2a9c1e7b3d52	worker-1	eu-west-3
i-034f2a9c1e7b3d53	worker-2	eu-west-3
i-044f2a9c1e7b3d54	cron	eu-west-3

ÉLEVÉE

6. Bases sans sauvegarde automatique

RDS

Risque. Aucune sauvegarde automatique : une erreur humaine ou une corruption serait irréversible.

Correction. Activer les sauvegardes automatiques (7 jours minimum).

Ressource	Détail	Région
analytics-mysql	mysql 8.4 · db.t4g.medium	eu-west-3

ÉLEVÉE

7. Utilisateurs console sans MFA

IAM · CIS 1.10

Risque. Ces utilisateurs se connectent à la console avec un simple mot de passe.

Correction. Imposer le MFA, ou mieux : migrer vers IAM Identity Center (SSO).

Ressource	Détail	Région
m.durand		global

MOYENNE

8. Instances surdimensionnées (Compute Optimizer)

EC2

Risque. D'après l'utilisation réelle, ces instances peuvent passer à une taille inférieure.

Correction. Redimensionner l'instance vers le type recommandé.

Économie estimée : 389 € / mois (4 672 € / an) · confiance élevée

Ressource	Détail	Région	€ / mois
i-0f3e9b2c4a1d	worker-1 · m5.2xlarge → m6g.xlarge	eu-west-3	212 €
i-02a7c1e9f4b0	worker-2 · c5.2xlarge → c6g.large	eu-west-3	177 €

MOYENNE

9. Engagement Compute Savings Plan recommandé

Savings Plans

Risque. D'après l'usage des 30 derniers jours, AWS recommande un engagement de 1,42 $/h sur 1 an.

Correction. Appliquer d'abord le redimensionnement, puis souscrire un Savings Plan.

Économie estimée : 318 € / mois (3 816 € / an) · confiance moyenne

Ressource	Détail	Région	€ / mois
Compute Savings Plan · 1 an · sans avance		global	318 €

MOYENNE

10. Volumes EBS non attachés

EBS

Risque. Ces volumes ne sont rattachés à aucune instance mais sont facturés chaque mois.

Correction. Créer un snapshot si nécessaire, puis supprimer le volume.

Économie estimée : 80,41 € / mois (965 € / an) · confiance élevée

Ressource	Détail	Région	€ / mois
vol-0a1b2c3d	gp2 · 500 Go	eu-west-3	47,30 €
vol-0e4f5a6b	gp2 · 250 Go	eu-west-3	23,65 €
vol-09c8d7e6	gp2 · 100 Go	eu-west-3	9,46 €

MOYENNE

11. NAT Gateways sans trafic

NAT Gateway

Risque. Moins de 100 Mo transférés sur 14 jours.

Correction. Supprimer la NAT Gateway inutile.

Économie estimée : 30,13 € / mois (362 € / an) · confiance élevée

Ressource	Détail	Région	€ / mois
nat-0b7d2e4f19a3	12 Mo / 14 j	eu-west-1	30,13 €

MOYENNE

12. VPC Flow Logs désactivés

VPC · CIS 3.7

Risque. Sans Flow Logs, aucune trace des connexions réseau.

Correction. Activer les Flow Logs vers S3.

Ressource	Détail	Région
vpc-0d4e5f6a	prod	eu-west-3

FAIBLE

13. Groupes de logs conservés indéfiniment

CloudWatch Logs

Risque. Ces groupes de logs n'ont aucune durée de rétention.

Correction. Définir une rétention adaptée (30 à 90 jours).

Économie estimée : 33,24 € / mois (399 € / an) · confiance moyenne

Ressource	Détail	Région	€ / mois
/aws/lambda/ingest	1 840 Go	eu-west-3	33,24 €

FAIBLE

14. Volumes gp2 à migrer vers gp3

EBS

Risque. gp3 coûte 20 % de moins que gp2 avec de meilleures performances de base.

Correction. Modifier le type de volume en gp3 (à chaud).

Économie estimée : 18,92 € / mois (227 € / an) · confiance élevée

Ressource	Détail	Région	€ / mois
vol-0123abcd	api-1 · 1000 Go	eu-west-3	18,92 €

FAIBLE

15. Instances sans aucun tag

EC2

Risque. Sans tags, les coûts ne peuvent pas être attribués.

Correction. Définir une politique de tagging.

Ressource	Détail	Région
i-0c1d2e3f4a5b		eu-west-3

FAIBLE

16. Versioning désactivé

S3

Risque. Sans versioning, une suppression accidentelle détruit définitivement les objets.

Correction. Activer le versioning avec expiration des anciennes versions.

Ressource	Détail	Région
exemple-uploads		eu-west-3

ANNEXE

Périmètre, méthode et limites

Compte	123456789012 (exemple-prod)
Régions	eu-west-3, eu-west-1
Services analysés	AWS Config, CloudTrail, CloudWatch Logs, EBS, EC2, Elastic Load Balancing, GuardDuty, IAM, Lambda, NAT Gateway, RDS, S3, Savings Plans, Security Hub, VPC
Date et durée	6 novembre 2026 · 74 s
Fenêtre d'observation	14 jours pour les métriques d'utilisation
Mode d'accès	Rôle IAM en lecture seule (aucune modification possible)
Référentiels	CIS AWS Foundations Benchmark v3.0, AWS Well-Architected (piliers Sécurité et Optimisation des coûts)
Taux de change	1 USD = 0.86 EUR (tarifs publics AWS eu-west-1)
Version de l'outil	SenseDrift 2.0.0

Méthode de notation

Le score de posture part de 100. Chaque **contrôle** en échec (et non chaque ressource) retire des points selon sa sévérité : critique −12, élevée −6, moyenne −2, faible −0,5. Les constats de coûts n'entrent pas dans le score. Notes : A ≥ 90, B ≥ 75, C ≥ 60, D ≥ 40, E < 40.

Niveau	Signification	Échéance conseillée
CRITIQUE	Exposition directe ou compromission possible sans effort particulier.	Sous 48 h
ÉLEVÉE	Faiblesse exploitable ou perte de données probable en cas d'incident.	Sous 2 semaines
MOYENNE	Écart aux bonnes pratiques augmentant le risque ou le coût.	Sous 1 mois
FAIBLE	Amélioration recommandée, risque limité.	Sous 3 mois

Couverture et limites

Les contrôles suivants n'ont pas pu être exécutés intégralement. L'absence de constat sur ces points ne vaut pas conformité.

Service	Région	Statut
GuardDuty	eu-west-1	Non vérifié — service non activé ou indisponible

Cet audit est une évaluation automatisée de la configuration à la date indiquée. Il ne constitue ni un test d'intrusion, ni une certification. Les estimations financières sont fournies à titre indicatif et ne constituent pas un engagement. Toute modification doit être testée au préalable sur un environnement hors production.